

MODULE 05

NETWORK FORENSICS

INTRODUCTION

- Network forensics focuses on capturing, recording, and analyzing network traffic to detect suspicious activities, investigate incidents, and understand how attacks occur.
- To do this effectively, you first need a strong grasp of how data moves across networks and what that data actually looks like “on the wire.” The TCP/IP model is the backbone of network communication. It consists of four layers: Application, Transport, Internet, and Network Access.
- The **Application layer** is where user-facing protocols operate, such as HTTP for web browsing, DNS for domain name resolution, and FTP for file transfers.
- The **Transport layer** is responsible for delivering data reliably or quickly, depending on the protocol used. TCP (Transmission Control Protocol) ensures reliable delivery through acknowledgments and retransmissions, while UDP (User Datagram Protocol) is faster but does not guarantee delivery.
- The **Internet layer** handles addressing and routing using IP addresses. It determines how packets travel from source to destination across multiple networks. This is where forensic analysts often identify suspicious IP addresses involved in attacks.
- The **Network Access layer** deals with the physical transmission of data over hardware such as Ethernet or Wi-Fi.

Packet Anatomy

- A packet is the fundamental unit of data transmitted across a network. Understanding its structure is critical in network forensics because attackers often hide malicious activity within normal-looking traffic.
- Each packet consists of two main parts: the header and the payload. The header contains metadata such as source and destination IP addresses, port numbers, protocol type, and sequence numbers.
- The payload contains the actual data being transmitted, such as part of a webpage or a file.
- For example, an IP header will show where the packet is coming from and where it is going, while a TCP header includes sequence numbers that help reassemble packets in the correct order.
- During an investigation, an analyst examines packet captures and if they notice a series of packets with unusual destination ports and encoded payloads for example, they might further analyze the headers, to find the source and destination of these packets.

Common Protocols (HTTP, DNS, FTP)

- Protocols define the rules for communication between devices. Some protocols are commonly analyzed in network forensics due to their frequent use and potential for abuse.
- HTTP (Hypertext Transfer Protocol) is used for web communication. It operates over TCP and typically uses port 80 (or 443 for HTTPS). Analysts often inspect HTTP traffic to detect malicious downloads, suspicious URLs, or data exfiltration.
- DNS (Domain Name System) translates domain names into IP addresses. Because it is essential for internet functionality, attackers often exploit DNS for covert communication or data exfiltration. For example, malware may encode data into DNS queries sent to attacker-controlled domains.
- FTP (File Transfer Protocol) is used to transfer files between systems. It is less secure because it transmits data, including credentials, in plaintext. Attackers may exploit FTP servers to upload or download sensitive data.
- For example, consider a company that experienced data leakage. Investigation shows that sensitive data was encoded into DNS queries and sent to an external server. Because DNS traffic is often trusted and less monitored, the attack went unnoticed for weeks.

Logs vs Packet Captures

- Network forensic analysis relies heavily on two types of data sources: logs and packet captures.
- Logs are records generated by systems such as servers, firewalls, and applications. They provide summarized information about events, such as login attempts, connection requests, or errors. Logs are easier to store and analyze but may lack detailed information.
- Packet captures (PCAPs) are full recordings of network traffic. They provide detailed insights into every packet transmitted, including headers and payloads.
- Tools like Wireshark are used to analyze PCAPs. While highly detailed, packet captures require significant storage and processing power.
- For example: An organization detects a breach. Logs show that a user connected to a suspicious IP, but they do not reveal what data was transferred.
- By analyzing packet captures, investigators discover that confidential files were exfiltrated via HTTP POST requests.

IDS/IPS Basics

- Intrusion Detection Systems (IDS) and Intrusion Prevention Systems (IPS) are essential tools in network security monitoring.
- An IDS monitors network traffic and alerts administrators when suspicious activity is detected. It does not take action but provides visibility.
- For example, it might alert when it detects a known attack signature or unusual traffic patterns.
- An IPS, on the other hand, actively blocks or prevents detected threats. It sits inline with network traffic and can drop malicious packets or terminate connections.
- There are two main detection methods: signature-based detection, which relies on known attack patterns, and anomaly-based detection, which identifies deviations from normal behavior.
- An IDS detects repeated login attempts from a foreign IP address and alerts the security team. However, the attack continues until an IPS is configured to block the offending IP automatically, stopping the brute-force attack.

IDS/IPS Basics

- Intrusion Detection Systems (IDS) and Intrusion Prevention Systems (IPS) are essential tools in network security monitoring.
- An IDS monitors network traffic and alerts administrators when suspicious activity is detected. It does not take action but provides visibility.
- For example, it might alert when it detects a known attack signature or unusual traffic patterns.
- An IPS, on the other hand, actively blocks or prevents detected threats. It sits inline with network traffic and can drop malicious packets or terminate connections.
- There are two main detection methods: signature-based detection, which relies on known attack patterns, and anomaly-based detection, which identifies deviations from normal behavior.
- An IDS detects repeated login attempts from a foreign IP address and alerts the security team. However, the attack continues until an IPS is configured to block the offending IP automatically, stopping the brute-force attack.

QnA

- If a packet fails to reach its destination and needs retransmission, which TCP/IP layer is responsible, and why?
- Why might an attacker manipulate packet headers instead of payloads to evade detection?
- Why is DNS traffic a popular channel for attackers to hide data exfiltration?
- In what situation would logs be insufficient, making packet capture analysis necessary?
- What is one advantage and one limitation of signature-based detection in IDS/IPS systems?

Packet Filtering

- Packet filtering is the process of narrowing down large volumes of network traffic to only the data relevant to your investigation.
- In real-world environments, networks generate millions of packets per minute, so analysts must apply filters to isolate suspicious activity efficiently.
- Filtering can be done based on IP addresses, ports, protocols, or specific keywords. For example, you might filter for all traffic going to a suspicious IP address or all DNS queries made by a specific machine.
- Tools like Wireshark allow both capture filters (applied before data is collected) and display filters (applied after capture).
- Example - An analyst investigating a malware infection filters traffic by the infected machine's IP address. They then narrow it further to only HTTP traffic and discover repeated connections to a suspicious domain every five minutes—indicating a beaconing pattern used by malware.

Following TCP Streams

- Following TCP streams is a technique used to reconstruct entire conversations between two devices.
- Since data is often split across multiple packets, analyzing a single packet may not provide meaningful context. By reassembling the packets in order, analysts can view the full communication.
- This is particularly useful when analyzing web traffic, login sessions, or file transfers.
- For example, HTTP requests and responses can be reconstructed to reveal full URLs, headers, and even transmitted data.
- Example - During an investigation, an analyst follows a TCP stream and discovers a login session where credentials are transmitted in plaintext. The attacker used this information to gain unauthorized access to a system.

Identifying Exfiltration Patterns

- Data exfiltration is the unauthorized transfer of data out of a network. Detecting it is one of the primary goals of network forensics.
- Exfiltration often follows recognizable patterns. These include unusually large data transfers, repeated outbound connections to unfamiliar IP addresses, or data sent at odd times (such as late at night).
- Attackers may also split data into smaller chunks to avoid detection or disguise it as normal traffic. Analysts look for anomalies such as spikes in outbound traffic, irregular packet sizes, or consistent intervals between transmissions (beaconing).
- Correlating these patterns with user activity can help confirm whether the behavior is legitimate or malicious.
- Example - A company notices a steady stream of small outbound packets being sent every minute. While each packet appears harmless, analysis reveals they contain fragments of a sensitive database being slowly exfiltrated to an external server.

Detecting Suspicious DNS Traffic

- DNS traffic is often overlooked, making it a common channel for attackers to exploit.
- Because DNS queries are typically allowed through firewalls, they can be used for covert communication or data exfiltration.
- Suspicious DNS behavior includes unusually long domain names, frequent queries to the same domain, or requests for domains that do not exist (NXDOMAIN responses).
- Attackers may encode data into subdomains, effectively hiding information inside DNS queries.
- Another red flag is communication with newly registered or low-reputation domains. These are often used in phishing campaigns or as command-and-control servers.
- An analyst detects a system making frequent DNS queries with long, random-looking subdomains. Upon decoding the queries, they discover that the system is sending encrypted data to an attacker-controlled server.

Live Packet Walkthrough

- A live packet walkthrough involves analyzing real or simulated packet capture data step by step. This is where all previously discussed concepts come together.
- An analyst typically starts by identifying basic details such as source and destination IPs, then applies filters to isolate relevant traffic. Next, they follow TCP streams to reconstruct sessions and inspect payloads.
- They also look for anomalies in protocols like DNS or HTTP and correlate findings with logs or alerts from IDS/IPS systems. The goal is to build a narrative of what happened: how the attack started, how it progressed, and what data was affected.
- For example - In a simulated exercise, an analyst reviews a packet capture and identifies a phishing attack. They trace the initial DNS request to a malicious domain, follow the HTTP stream to a fake login page, and observe credentials being submitted.
- Further analysis shows the compromised system communicating with a command-and-control server.

QnA

- Why would an analyst prefer display filters over capture filters during an ongoing investigation?
- What risks arise when sensitive data is transmitted over TCP without encryption?
- Why might attackers choose to exfiltrate data slowly instead of transferring it all at once?
- What characteristics of a DNS query might indicate that it is being used for covert data transmission?
- When analyzing a packet capture from scratch, what should be your first step—and why is it important not to jump straight into deep packet inspection?

Case Study: The Equifax 2017 data breach

- The Equifax breach is one of the most significant real-world examples of how network forensics, vulnerability management, and monitoring failures can combine into a large-scale disaster.
- It exposed the personal data of over 147 million people and highlighted critical weaknesses in patching and network visibility.
- The root cause of the breach was a known vulnerability in Apache Struts i.e. the attackers sent a specially crafted HTTP request that the vulnerable server failed to properly validate. Instead of rejecting the malicious input, the server executed it as a system command, giving attackers control.
- Equifax had been notified of the vulnerability and a patch was available. However, one of their public-facing web applications remained unpatched. Attackers scanned the internet for systems running vulnerable versions of Apache Struts, found Equifax's server, and exploited it to gain initial access.

Case Study: The Equifax 2017 data breach

- Once inside the network, attackers did not act immediately. Instead, they established persistence and began exploring internal systems. Network traffic analysis could have revealed several warning signs.
- Some likely indicators included:
 - Repeated outbound connections to unfamiliar external IP addresses
 - Unusual HTTP or HTTPS requests containing encoded data. Internal systems communicating in ways they normally wouldn't (lateral movement)
 - Large volumes of outbound data transfers over time.
- Attackers often use encrypted channels (HTTPS) to blend in with legitimate traffic, making detection more difficult. However, patterns such as timing, frequency, and destination can still raise red flags.

Case Study: The Equifax 2017 data breach

- Network forensics played an instrumental, albeit delayed role in the 2017 Equifax data breach, by enabling the detection of suspicious traffic which facilitated the investigation by third-party firm Mandiant, and tracing the scope of the exfiltrated data.
- This traces revealed that the hackers exploited an unpatched Apache struts vulnerability because a crucial network monitoring device had been inactive for 19 months due to an expired security certificate.
- Lateral movement tracking revealed through forensic investigations that hackers stole internal credentials to move data from the initial compromised server to other servers, accessing 48 different servers in total.
- The breach went unnoticed for 76 days but forensic analysis of network logs allowed the investigators to reconstruct the actions from May to July 2017, determining the encrypted files were used to mask the movement of stolen data.
- One of the reasons the breach was not discovered earlier was because the security team was unable to inspect internal traffic due to the expired certificate which prevented the decryption of data in transit.

Case Study: The Equifax 2017 data breach

- The Equifax breach demonstrates that:
 - Known vulnerabilities are often the easiest entry points for attackers
 - Network traffic analysis can reveal subtle signs of compromise
 - Encryption does not eliminate visibility—it shifts focus to traffic patterns
 - Security tools are only effective if properly maintained and monitored
- Why are web application vulnerabilities like Apache Struts often more dangerous than traditional malware infections?
- If most traffic is encrypted (HTTPS), what metadata can still help detect suspicious behavior?
- If you were a network forensic analyst at Equifax, what combination of indicators (logs, traffic patterns, alerts) would you prioritize to detect the breach earlier—and why?

- END